

Security+ 2.3 · OS Vulnerabilities

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.3 — OS Vulnerabilities (4:09)** ·

[Vídeo no YouTube ↗](#)

Resumo da Aula: Falha no sistema operacional (kernel, serviços, bibliotecas). Windows tem Patch Tuesday — dezenas de correções por mês. SO sem patch = alvo fácil. Zero-day OS = sem correção disponível. Defesa: patch ASAP, EDR.

Highlights que a prova cobra

- Patch Tuesday: Microsoft corrige dezenas de CVE por mês
- Legacy (XP): sem suporte, sem patch — desativar/segmentar

Dicas de prova & Cenários Típicos

- 'operating system lacks patches' = legacy/unsupported OS vulnerability

Cenário clássico de exame: Cenário: 'Windows XP na rede industrial porque o software crítico não roda no moderno' = legacy OS risk.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 2.3)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (OS Vulnerabilities) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Atores de Ameaça (Threat Actors): Nation-state / APT (Advanced Persistent Threat):** altamente financiado, sofisticado, motivado por espionagem geopolítica a longo prazo. **Cybercriminal:** motivado por lucro financeiro direto (ransomware, extorsão). **Hacktivist:** motivado por causas políticas ou ideológicas. **Insider Threat:** funcionário ou terceiro com acesso legítimo que abusa de privilégios por dolo ou negligência.
- **Engenharia Social e Variantes de Phishing:** **Phishing:** campanha em massa por e-mail. **Spear Phishing:** ataque direcionado a indivíduo ou empresa específica usando dados de OSINT. **Whaling:** direcionado a executivos do C-level (CEO, CFO). **Vishing:** phishing por voz/telefone. **Smishing:** phishing por SMS. **BEC (Business Email Compromise):** impersonação de diretoria para desvio de faturas ou transferências bancárias.
- **Tipos de Malware e Vetores de Ataque:**
 - *Ransomware:* cifra dados corporativos e exige resgate em criptomoeda.
 - *Trojan:* software aparentemente inofensivo que instala backdoors ocultos.
 - *Rootkit:* modifica o kernel do sistema operacional e se oculta de ferramentas antivírus comuns.
 - *Worm:* malware autorreplicável que se propaga sozinho pela rede sem intervenção humana.
- **Vulnerabilidades de Aplicação (OWASP Top 10):**
 - *SQL Injection (SQLi):* manipulação de queries de banco de dados por falta de sanitização/parametrização (prepared statements).
 - *XSS (Cross-Site Scripting):* injeção de scripts maliciosos (JavaScript) no navegador da vítima.
 - *CSRF (Cross-Site Request Forgery):* induz a vítima logada a executar ações indesejadas em uma aplicação web confiável.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- Phishing não é mitigado apenas por filtros de e-mail; o controle humano fundamental é a simulação periódica de phishing e conscientização.
- Rootkits operam no nível de anel de privilégio (Ring 0 / Kernel), exigindo verificação de Secure Boot (TPM) para prevenção confiável.

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Vulnerabilidade que o fabricante ainda não conhece e não tem correção é chamada de:

- A)** CVE pública
- B)** Zero-day
- C)** Backdoor
- D)** Falso positivo

2. Qual tipo de ataque explora vulnerabilidades antes que um patch esteja disponível?

- A)** Ataque de dia zero (Zero-day)
- B)** Ataque DDoS
- C)** Ataque de força bruta
- D)** Ataque Man-in-the-Middle

3. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Patch Tuesday: Microsoft corrige dezenas de CVE por mês'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas de CVE por mês...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Legacy (XP): sem suporte, sem patch — desativar/segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desativar/segmentar...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'operating system lacks patches' = legacy/unsupported OS vulnerability'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'operating system lacks patches' = legacy/unsupported OS vulnerability...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'Windows XP na rede industrial porque o software crítico não roda no moderno' = legacy OS risk.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial porque o software crítico não roda ...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Patch Tuesday: Microsoft corrige dezenas de CVE por mês'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas de CVE por mês...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Legacy (XP): sem suporte, sem patch — desativar/segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desativar/segmentar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'operating system lacks patches' = legacy/unsupported OS vulnerability'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'operating system lacks patches' = legacy/unsupported OS vulnerability...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (OS Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'Windows XP na rede industrial porque o software crítico não roda no moderno' = legacy OS risk.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial porque o software crítico não roda ...

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — Zero-day.

✓ **Por que está certa:** Zero-day = falha desconhecida do fornecedor, sem patch — o defensor tem 'zero dias' pra se preparar. CVE pública já é catalogada e geralmente tem correção.

✗ **Por que as outras estão erradas:**

- *CVE pública:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Backdoor:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Falso positivo:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — Ataque de dia zero (Zero-day).

✓ **Por que está certa:** Zero-day é uma vulnerabilidade recém-descoberta que é explorada antes do desenvolvedor ter conhecimento ou lançar correção (dia zero de conhecimento).

✗ **Por que as outras estão erradas:**

- *Ataque DDoS:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Ataque de força bruta:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Ataque Man-in-the-Middle:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) B — Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas de CVE por mês....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Patch Tuesday: Microsoft corrige dezenas de CVE por mês.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desativar/segmentar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Legacy (XP): sem suporte, sem patch — desativar/segmentar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: 'operating system lacks patches' = legacy/unsupported OS vulnerability....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): 'operating system lacks patches' = legacy/unsupported OS vulnerability.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial porque o software crítico não roda

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Cenário: 'Windows XP na rede industrial porque o software crítico não roda no moderno' = legacy OS risk..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Patch Tuesday: Microsoft corrige dezenas de CVE por mês....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Patch Tuesday: Microsoft corrige dezenas de CVE por mês.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: Legacy (XP): sem suporte, sem patch — desativar/segmentar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Legacy (XP): sem suporte, sem patch — desativar/segmentar.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'operating system lacks patches' = legacy/unsupported OS vulnerability....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): 'operating system lacks patches' = legacy/unsupported OS vulnerability.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Cenário: 'Windows XP na rede industrial porque o software crítico não roda

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (OS Vulnerabilities): Cenário: 'Windows XP na rede industrial porque o software crítico não roda no moderno' = legacy OS risk..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.